



Lab 11 — Design Deployment Gates and Continuous Monitoring

Topic 03: Governance Controls Across the AI Lifecycle

Objective: Develop the deployment gate and the monitoring regime that keep an AI system governed after it goes live.

Goal: Most AI governance stops at launch, which is exactly where AI risk begins to change. You will design NovaBank's deployment gate — the evidence required to go live — and the monitoring regime that detects drift, abuse and failure afterwards, with defined thresholds and response actions.

What you'll build: A deployment gate checklist with named approvers, plus a monitoring specification with ten metrics, thresholds, alert routing and response actions.

Tools and data: Deployment gate template, monitoring log extract (agent-monitoring-log.csv), threshold worksheet

Data files in this lab

- data/agent-monitoring-log.csv
- data/deployment-gate-template.md
- data/monitoring-spec-template.csv

Step-by-step

1. Open the deployment gate template in labs/lab-11-deployment-monitoring/data/ and list the evidence a system must present to pass: risk assessment, data approval, test results, human-oversight design, rollback plan and transparency notice.
2. Assign a named approver role to each evidence item, reusing the RACI you built in Lab 7. An unapproved gate item must block deployment — decide now what happens when the business wants to launch anyway.
3. Write the exception process: who can accept residual risk, for how long, and what compensating control is required. Every exception needs an expiry date.
4. Open agent-monitoring-log.csv and examine the fields: timestamp, agent ID, user, tool called, tokens, latency, refusal flag, injection-detected flag and outcome.
5. Find the anomalies in the log. Look for a spike in tool calls from one agent, a run of refusals, an unusual out-of-hours access pattern and a sequence where an injection flag precedes an external send.
6. Define ten monitoring metrics across four categories: quality (accuracy, groundedness), safety (refusal rate, injection-detection rate), operations (latency,

cost per call, error rate) and security (permission escalations, out-of-hours access, external sends, anomalous tool sequences).

7. Set a threshold for each metric and state what triggers the alert. A metric with no threshold is a dashboard, not a control.
8. Define the response action for each alert: who is notified, what they check first, and the condition under which the agent is disabled. Record how long disabling should take — measure it, because you will be asked.
9. Design the drift review: how often the system is re-assessed, what evidence is refreshed, and the trigger that forces an early re-assessment such as a model version change or a new tool being added.
10. Write the decommissioning checklist: revoke credentials, dispose of memory and embeddings, preserve audit logs for the retention period, and update every dependent system.

Test it

Every one of your ten metrics has a numeric threshold and a named response action. Using the log extract you can point to at least three anomalies and state which of your alerts would have fired on each.

Training use only. The organisation, data and individuals in this lab are fictional. Security techniques taught here must only be applied to systems you own or have written authorisation to test.